Chainsmith

Automatically Learning the Semantics of Malicious Campaigns by Mining Threat Intelligence Reports

Zhu et al., 2008 IEEE European Symposium on Security and Privacy

Introduction

What is Threat Intelligence?

- Refers to the gathering and analysis of information about security threats.

- Sharing the technical details makes everyone safer as attackers cannot reuse their tactics.

Contributions made by this paper:

- Design of ChainSmith, an IOC extraction system.
- Evaluation of the effect of different persuasion techniques used by attackers.
- Setting up of a WebApp to release the latest data from ChainSmith to further stimulate Threat Intelligence.

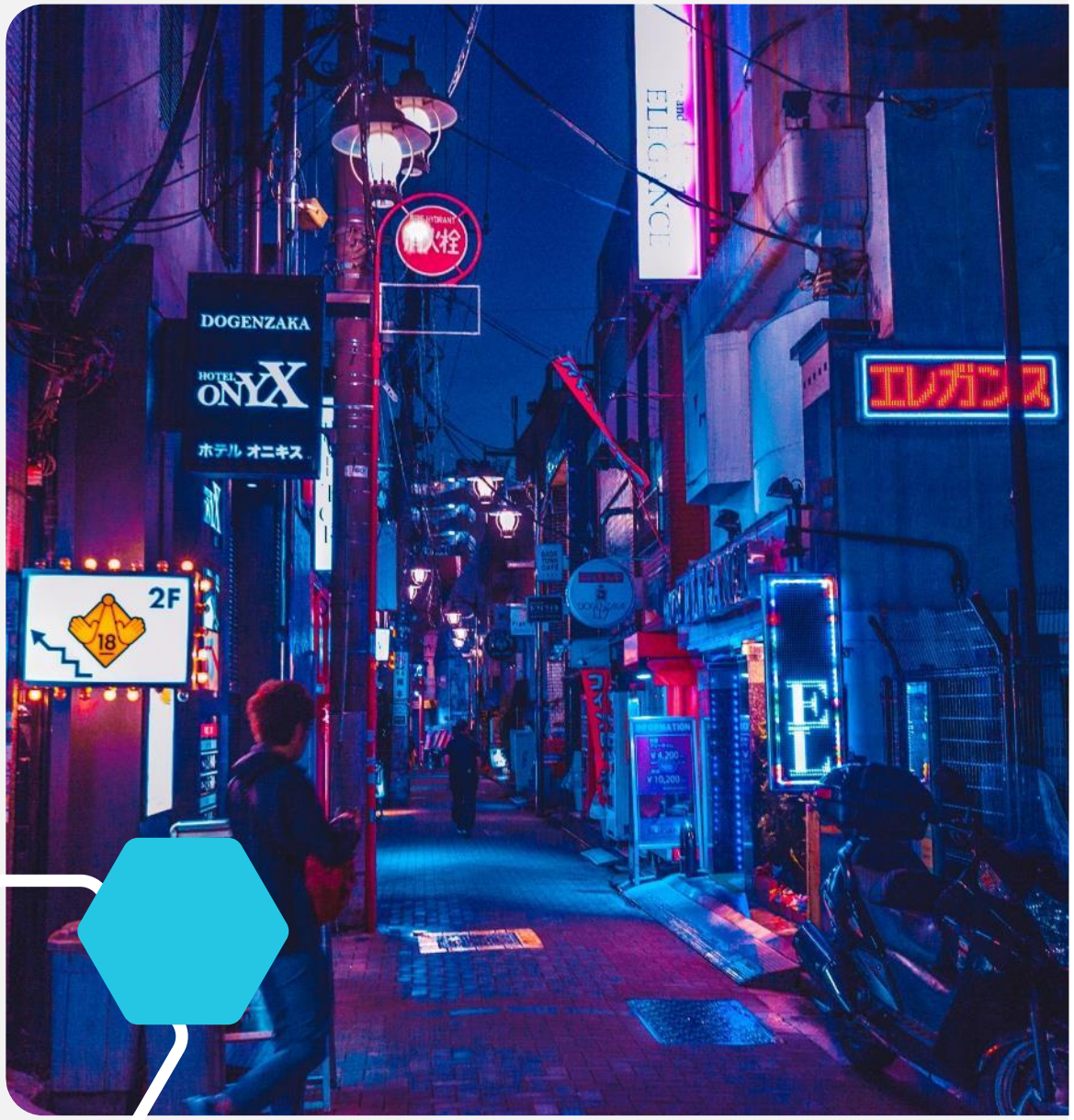
Problem Statement

Problem Statement

- Threat intelligence reflects a careful manual analysis of security threats, with conclusions from experts.
- These conclusions are encoded in *Indicators of Compromise* (IOCs), which is some observable entity.
- Security tools based on IOC may not always provide adequate defense.

Novel Approach

- An attempt to link measurement data to threat intelligence.
- This gives new insights about attacker strategies from the measurement data and analysis about the impact of attacks.



Use Case

Malware delivery

- Neither threat intelligence nor measurement techniques can provide a complete picture of malware delivery campaigns.
- These insights require connecting both.

Goals

- Extraction of threat intelligence in a manner that complements measurement data.
- Extraction of both IOCs and their roles in an attack.
- Examining the usefulness of threat intelligence.

Malware Delivery Model

Cyber attacks usually follow certain patterns:

The STIX schema defines a ‘campaign’ to be a set of ‘indicators’, which are a set of ‘observables.

‘Observables are like IOCs, and are of 88 different types, including URL, IP address, etc.

The stages selected from the STIX data model for this paper are:

1. Baiting

Email spam, malvertising and compromised sites.

2. Exploitation

The exploit server tries to identify vulnerabilities to deliver the payload

3. Installation

A malicious payload is downloaded and installed to execute the malware.

(This step may happen without step 2 occurring before it too.)

4. Command and Control

The malware contacts its command and control server and receives instructions to perform malicious acts.

```
{
    baiting: {
        server_URL: ["www.alacinc.org.nz"]
    },
    exploitation: {
         server_URL: ["netgear-india.net”],
         exploited_vulnerability: ["CVE-2010-0188”],
         exploit_kit: ["Black Hole”]
    },
    installation: {
        malware_hash: [“80601551f1c83ee326b3094e468c6b42”],
        malware_family: ["UDS:DangerousObject.Multi.Generic"]
    },
    C&C: {
        C&C_server_IP: ["200.169.13.84:8080"]
    }
}
```

Threats to Validity

- Malware may not be detected as soon as it is released into the wild.
- Threat intelligence reports may be incorrect.

Data Set

- Data collected using Symantec's WINE platform.
- This data is not entirely complete, as it does not observe long running campaigns.
- This data is utilised to demonstrate how ChainSmith can fill the gaps in measurement data with threat intelligence.

Experimental Methods

Article Crawler

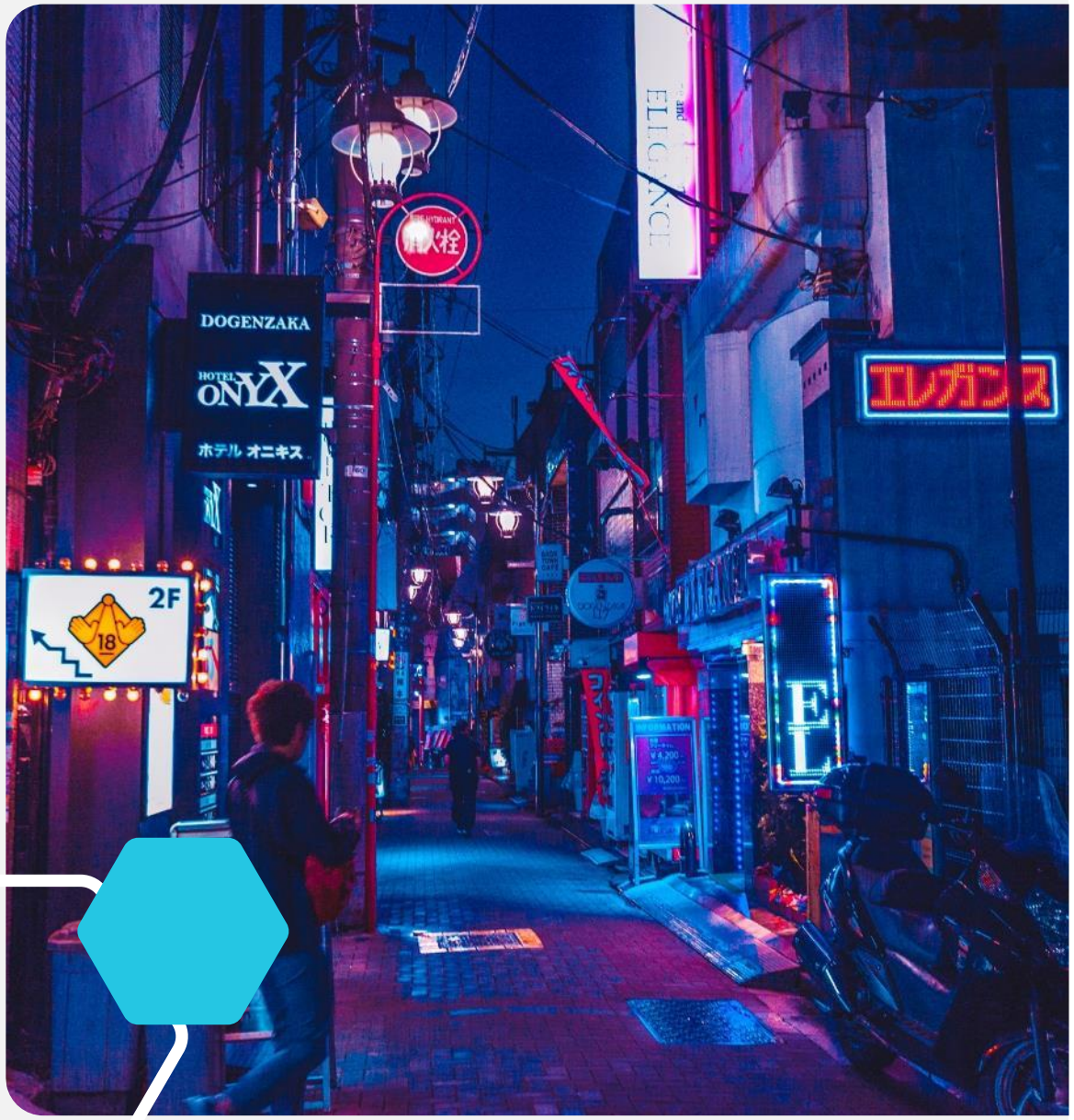
- A generic crawler is implemented to collect security articles online.
- This helps to gain a full picture of an end-to-end campaign.
- The sources are made to be very diverse.

Expression Detector

- Security narratives often include muti-word expressions.
- Such expressions are identified using a method proposed by *Mikolov et al.*

Syntactic Parser

- This performs tokenizing and dependency parsing, which converts the string into a tree structure to represent word dependency.
- Python NLTK and Stanford CoreNLP are used.



Semantic Parser

- To consider the meaning of the words too, semantic parsing is done using *word2vec*.
- The words with close semantic meaning will be represented in a close position in vector space.

Named Entity Recognition

- Regular expressions are used to identify candidate IOCs

IOC Classifier

- Goal is to identify whether a word is an IOC, and the stage of the campaign it belongs to.
- The classifier considers features both at the dependency tree and sentence levels.
- For each sentence, we look at context from three sources:
  1. Informative words from the current sentence.
  2. Informative words from the previous sentence.
  3. Informative words from the previous sentence that mention the same IOC

IOC Classifier (Contd.)

First, we need to identify informative words.

The following equation is used:

$$S(w) = \max_{t \in T} \frac{p(w|t)}{p(w)}$$

where,

- T is the set of malware campaign phases
- *w* is the word we evaluated
- *p(w)* is the probability of word *w*
- *p(w)* is the probability that word *w* will be used for describing topic *t.*

IOC Classifier (Contd.)

Features used to identify the sentence topic:

- Average word embedding of the context words.
- Average word embedding of the article title.
- Number of IOCs of each type.

Four binary classifiers are trained to identify topic probabilities. The classifier is implemented using neural network with one hidden layer and fifty hidden nodes.

To verify that the named entities identified represent IOCs of some campaign, a multi-class classifier for each class type is trained, which contains:

- The probability of each topic.
- Average dependency embedding for all dependencies connected to the named entity.
- Type specific features (URL and IP only)

Campaign Group Identification

- We assume that each technical article discusses one supplier and multiple consumers.
- For each articles, all the IOCs in the baiting and exploitation phase are grouped as one and all the other IOCs go to separate groups.
- If two campaigns contain identical IOCs and appear within a short time frame of each other, then we consider them to be a part of the same campaign.
- Threshold: 6 months

Performance

Baseline uses traditional topic modelling.

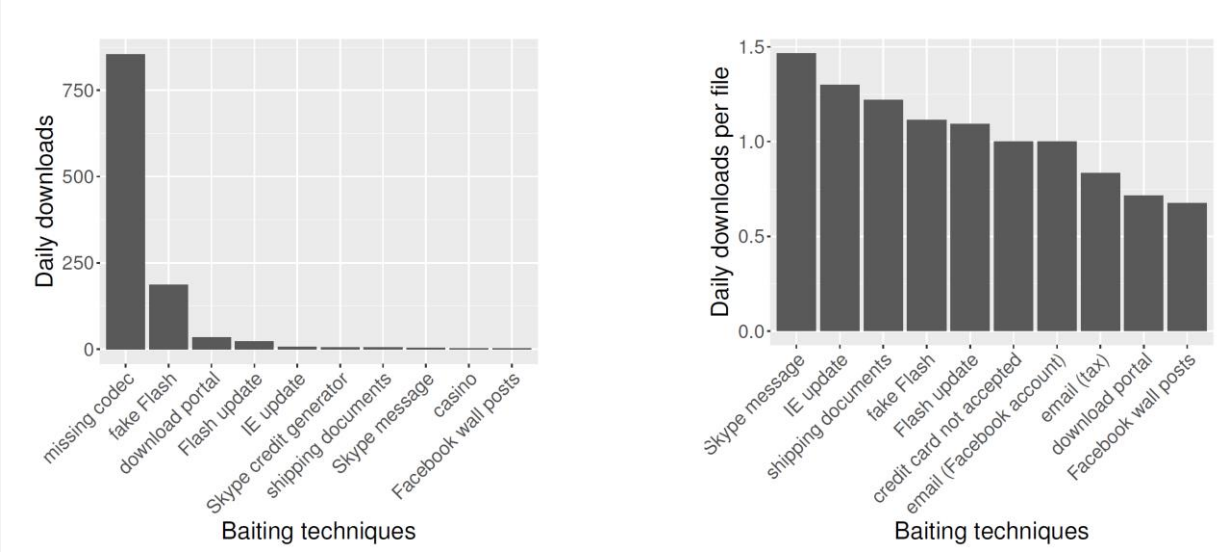
IOC detection		
	Precision	Recall
ChainSmith	91.9%	97.8%
Baseline	78.2%	66.7%
Stage classification		
	Precision_avg	Recall_avg
ChainSmith	78.2%	69.6%– 80.7%
Baseline	37.0%	28.7%

Stage	Attribute	Count
baiting	server_URL	4,874
	server_IP	1,001
exploitation	exploit_site_URL	3,735
	exploit_site_IP	732
	exploited_vulnerability	554
	exploit_kit	572
installation	malware_hash	4,263
	malware_family	1,604
C&C	C&C_server_URL	2,161
	C&C_server_IP	1,271
unknown		3,879
Total		24,653

Summary of extracted IOCs

Persuasion Techniques

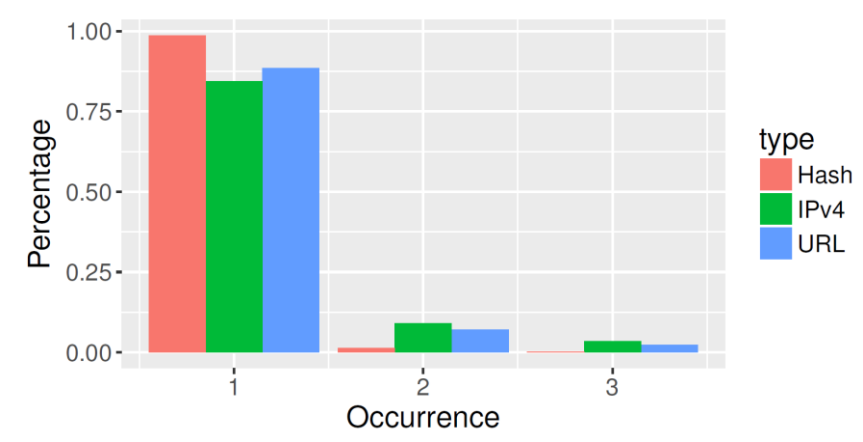
- Attackers design creative persuasion methods.
- Social engineering does not involve exploitation and intrusion, and happens with the consent of the victim.
- Eg: Download a ‘missing plugin’ to play an online video.



Lifecycles of campaigns and infrastructure

- Most campaign groups use social engineering for delivery.
- Most of the domains used in exploitation and intrusion may change frequently and hence it is difficult to use IOCs for long-running campaigns.

This has important implications for threat intelligence.



- However, domains may still be useful as attackers may reuse some of their infrastructure.
- Attackers may also reuse an old domain/IP once it is off the blacklists.

Discussion

Persuasion Techniques

- Users are enticed through social engineering.
- No malicious behaviour while downloading, hence harder to detect.
- These campaigns are usually long-running
- Can be detected by the language of the malvertisements.

Campaign Detection

- The focus has traditionally been on malicious behaviour, and not unexpected behaviour.
- The easiest way out is to block the malvertisements.

Threat Intelligence

- Threat intelligence makes it possible for the security researchers to explain the measurement data.
- It is extremely useful to club threat intelligence with measurement data.
- Relationships among IOCs is another useful tool.

Conclusion

- ChainSmith automatically extracts IOCs from articles/reports and classifies them into different campaign stages.
- This makes is possible to combine threat intelligence with field-gathered data.
- ChainSmith achieves 91.9% precision and 97.8% recall for extracting IOCs from natural language documents.
- It was found that most campaigns deliver payloads through social engineering.
- Media player advertising – ‘missing codec’ – is the most persuasive and potent.
- Finally, some light is shed on the use cases for leveraging IOCs in security forensics.

Zhu, Ziyun, and Tudor Dumitras. "Chainsmith: Automatically learning the semantics of malicious campaigns by mining threat intelligence reports." *2018 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, 2018.

Thank You.

Kabir Kanha Arora
ka682@snu.edu.in